

CISSP Printable Practice Exam 28 - Domain 4 - Communication and Network Security

Practice Exam 04 - Domain 4

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-060)

Scenario: A corporate office experiences intermittent interception of traffic within one IPv4 subnet. Investigation shows that a malicious workstation is sending forged address resolution messages so other hosts associate the default gateway address with the attacker's network interface.

Which control would MOST directly mitigate this attack?

- A. Increase the external firewall's idle session timeout.
- B. Change the public DNS record for the default gateway.
- C. Use trusted address-binding information to validate address resolution messages on access switches.
- D. Enable route summarization on the Internet edge router.

Question 2 (CISSP4-061)

Scenario: Managed laptops have begun sending encrypted DNS queries directly to various external resolvers, bypassing the organization's approved filtering and logging service. The organization still wants confidentiality for DNS traffic.

Which response BEST satisfies both requirements?

- A. Permit every external encrypted resolver because encrypted traffic is inherently trusted.
- B. Direct managed endpoints to an approved encrypted resolver and restrict unauthorized resolution paths.
- C. Disable DNS logging while allowing clients to select any resolver.
- D. Replace DNS names with a spreadsheet of fixed public addresses.

Question 3 (CISSP4-062)

Scenario: Employees initiate outbound TCP sessions to an approved service on a well-known destination port. Return packets arrive at temporary high-numbered client ports, and an administrator proposes permanently allowing all inbound traffic to those ports.

What is the BEST policy approach?

- A. Permit all inbound high-numbered ports because they are never used by listening services.
- B. Block all return packets and require the external server to initiate new connections.
- C. Assign every client the same fixed source port and publish it externally.
- D. Use stateful inspection to allow return packets only for valid sessions initiated from inside.

Question 4 (CISSP4-063)

Scenario: Different perimeter devices process long or unusual IPv6 extension-header chains inconsistently. Some devices forward packets that downstream inspection tools cannot fully parse, creating an evasion opportunity.

Which action is MOST appropriate?

- A. Establish and test a consistent boundary policy that permits required headers and rejects malformed or unsupported chains.

- B. Allow every extension-header combination so no legitimate application is interrupted.
- C. Inspect only the source MAC address because extension headers are a link-layer function.
- D. Disable all IPv4 monitoring because the issue was observed in IPv6.

Question 5 (CISSP4-064)

Scenario: A rapidly growing office network has one large Layer 2 segment. Excessive broadcast traffic now affects devices that have no need to communicate directly with one another.

Which TWO statements correctly support a safer redesign? Select 2 of the 5 options below.

- A. A router forwards ordinary Ethernet broadcasts to every connected subnet by default.
- B. Dividing the environment into smaller routed segments limits each broadcast domain.
- C. Changing application TCP ports prevents all link-layer broadcasts.
- D. Inter-segment policy can restrict which traffic crosses the routed boundary.
- E. A larger flat VLAN reduces the number of hosts affected by a broadcast storm.

Question 6 (CISSP4-065)

Scenario: A wholesale company receives inventory files from many suppliers. Suppliers must upload data without connecting to the internal processing network, and internal services should retrieve only scanned and approved files.

Which architecture BEST meets the requirement?

- A. Allow each supplier VPN unrestricted routing to the processing servers.
- B. Use an isolated transfer zone with separate external upload and controlled internal retrieval paths.
- C. Place the transfer service directly on the employee workstation network.
- D. Give suppliers shared administrator access to the internal file repository.

Question 7 (CISSP4-066)

Scenario: A small temporary project site cannot operate enterprise authentication infrastructure. It must use a shared wireless credential, but the security manager wants stronger resistance to offline password guessing than a legacy preshared-key handshake provides.

Which option is MOST suitable?

- A. An open network with a web acceptance page
- B. A hidden network name with legacy encryption
- C. WPA3-Personal using Simultaneous Authentication of Equals and a strong passphrase
- D. MAC address filtering without wireless encryption

Question 8 (CISSP4-067)

Scenario: A software company discovers that compromised cloud workloads can connect directly to arbitrary Internet destinations. Security teams need centralized destination control and logs without assigning public addresses to every workload.

Which design BEST addresses the concern?

- A. Allow each workload to choose its own Internet gateway and logging format.
- B. Assign public addresses to all workloads and depend on changing addresses for protection.
- C. Permit unrestricted outbound traffic because the workloads cannot accept inbound

sessions.

D. Route egress through controlled gateways or proxies that enforce destination policy and centralize logs.

Question 9 (CISSP4-068)

Scenario: A managed hosting provider creates logically isolated customer networks over shared switches and hypervisors. A configuration defect in the overlay could expose traffic between tenants even though their address spaces appear separate.

What should the security manager prioritize?

- A. Automated policy validation and recurring tests that verify tenant traffic cannot cross logical boundaries.
- B. A larger shared subnet so all tenants use the same forwarding table.
- C. Removal of overlay identifiers to simplify packet headers.
- D. Reliance on customer naming conventions as evidence of network isolation.

Question 10 (CISSP4-069)

Scenario: A public licensing portal experiences large traffic floods that saturate its single Internet connection. The static public content can be distributed globally, but attackers must not be able to bypass the distribution layer and target the origin directly.

Which approach BEST improves resilience?

- A. Publish the origin address alongside the distributed address so clients can choose either path.
- B. Increase origin session timeouts so attack connections remain stable.
- C. Use a distributed delivery and traffic-scrubbing service while restricting origin access to approved service paths.
- D. Move all static content into the internal user network during an attack.

Question 11 (CISSP4-070)

Scenario: A remote office currently uses stateless packet filters. The organization wants return traffic permitted only when it belongs to a legitimate outbound session, rather than maintaining broad rules for possible reply ports.

Which control capability BEST meets the objective?

- A. A packet filter that evaluates only source addresses
- B. A network hub that repeats frames to every connected port
- C. A router that accepts every route learned from the local segment
- D. A stateful firewall that tracks connection establishment and session status

Question 12 (CISSP4-071)

Scenario: A payment clearing network uses a single inline intrusion prevention device. A device failure recently interrupted all traffic, but configuring an unconditional bypass would allow uninspected connections during future failures.

Which design BEST balances availability and security?

- A. Retain the single device and increase its alert retention period.
- B. Use an unconditional bypass that silently forwards all traffic after any inspection error.
- C. Deploy redundant inline inspection with tested failover, health monitoring, and a documented failure policy.
- D. Remove intrusion prevention and rely on endpoint naming conventions.

Question 13 (CISSP4-072)

Scenario: A damaged device at a distribution warehouse begins transmitting excessive broadcast frames. Access switches forward the traffic throughout the local segment, disrupting scanners and voice terminals.

Which switch control would MOST directly limit the immediate impact?

- A. Rate-limit abnormal broadcast and multicast traffic on access ports and alert on threshold violations.
- B. Increase the maximum number of learned MAC addresses on every port.
- C. Extend address table aging so entries remain active longer.
- D. Enable dynamic trunking on the damaged device's port.

Question 14 (CISSP4-073)

Scenario: A citizen services portal requires users to remain on the same application node during a transaction. The current load balancer inserts a client-visible token containing an unprotected internal server name, making infrastructure details easy to discover and manipulate.

Which remediation is BEST?

- A. Expose additional server details so clients can recover from routing errors.
- B. Use an opaque, integrity-protected persistence value and validate it before routing.
- C. Allow clients to submit any internal server name as the routing decision.
- D. Disable validation of persistence data to reduce load balancer processing.

Question 15 (CISSP4-074)

Scenario: A historic building must retain copper network cabling that passes through publicly accessible ceiling spaces. Replacement with fiber is not currently feasible, but the organization must reduce interception and tampering risk.

Which TWO safeguards BEST address the exposure? Select 2 of the 5 options below.

- A. Route the cable through protected conduit with controlled access to termination points.
- B. Label the cable with confidential system names so maintenance workers can identify it.
- C. Add unattended couplers in public spaces to make troubleshooting easier.
- D. Use appropriate shielding and monitor links or enclosures for unexpected physical changes.
- E. Rely on the building's height as the sole protection against signal interception.

Question 16 (CISSP4-075)

Scenario: A branch gateway must establish an IPsec connection through an upstream device that performs network address translation. The original deployment fails because the translated path modifies addressing information used by the protected exchange.

Which solution is MOST appropriate?

- A. Expose the branch's internal hosts directly to avoid gateway translation.
- B. Replace the protected tunnel with an unencrypted routing session.
- C. Disable peer authentication so translated addresses are accepted automatically.
- D. Use IPsec NAT traversal support and validate the resulting gateway policy.

Question 17 (CISSP4-076)

Scenario: A media production company permits administrators to manage servers from outside

the office. Direct remote desktop exposure has produced repeated login attacks, and the company needs session accountability and a single point for terminating access.

Which design BEST meets these needs?

- A. Publish every server's management port and rely on unique port numbers.
- B. Require access through a hardened gateway with strong authentication, target restrictions, and session logging.
- C. Use one shared administrator credential so sessions appear under a consistent identity.
- D. Permit direct connections from any address after business hours.

Question 18 (CISSP4-077)

Scenario: A customer support center connects its internal voice system to an external service provider. Recent spoofed signaling attempts sought to establish unauthorized international calls through the connection.

Which approach provides the BEST protection at this boundary?

- A. Use a voice-aware boundary controller with authenticated signaling, restricted call routes, and anomaly monitoring.
- B. Accept signaling from any Internet source if it requests a supported codec.
- C. Permit every destination so failed calls can use alternate international routes.
- D. Disable call-detail logging because signaling is handled by the provider.

Question 19 (CISSP4-078)

Scenario: A cloud operations team moves virtual workloads between data centers over carrier infrastructure it does not control. Security policy must continue to follow each workload, and east-west traffic must remain protected while crossing the external underlay.

Which TWO controls BEST satisfy the requirements? Select 2 of the 5 options below.

- A. Trust the carrier underlay to identify every workload by its physical switch port.
- B. Remove workload-level policy whenever a virtual machine changes hosts.
- C. Bind segmentation policy to stable workload identity rather than only physical location.
- D. Allow all overlay members to communicate because the network is virtualized.
- E. Protect overlay traffic across the untrusted underlay with authenticated encryption.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-060) - Correct: C

Access-switch validation based on trusted IP-to-MAC bindings can reject forged address resolution messages on the local segment. External firewall timers, public DNS, and route summarization operate outside the local resolution process and do not stop the spoofing behavior.

Question 2 (CISSP4-061) - Correct: B

An approved encrypted resolver preserves query confidentiality while maintaining organizational filtering and audit visibility. Allowing arbitrary resolvers bypasses policy, disabling logs removes accountability, and fixed address lists are not a scalable or reliable substitute for name resolution.

Question 3 (CISSP4-062) - Correct: D

Stateful inspection associates return packets with an established outbound session, avoiding a broad inbound exception for ephemeral ports. High-numbered ports can still host services, blocking replies breaks legitimate sessions, and forcing a shared source port is neither necessary nor scalable.

Question 4 (CISSP4-063) - Correct: A

A tested, consistent policy prevents devices from interpreting the same IPv6 traffic differently while retaining required functionality. Permitting every chain preserves the evasion path, MAC inspection cannot evaluate IPv6 headers, and removing IPv4 monitoring is unrelated to the problem.

Question 5 (CISSP4-064) - Correct: B, D

Smaller routed segments contain broadcast traffic, and policy at their boundaries can limit permitted inter-segment communication. Routers do not normally forward ordinary Ethernet broadcasts between subnets, application port changes do not eliminate link-layer broadcasts, and a larger flat VLAN increases the potential impact.

Question 6 (CISSP4-065) - Correct: B

An isolated transfer zone separates untrusted supplier sessions from internal processing and supports scanning before controlled retrieval. Broad VPN routing, workstation placement, and shared administrative access expose internal systems beyond the stated business need.

Question 7 (CISSP4-066) - Correct: C

WPA3-Personal uses Simultaneous Authentication of Equals, which improves resistance to passive offline password attacks while supporting a shared credential. A captive page, hidden name, or MAC filtering does not provide equivalent wireless authentication and confidentiality.

Question 8 (CISSP4-067) - Correct: D

Controlled egress gateways or proxies provide a consistent inspection, restriction, and logging point without exposing each workload publicly. Decentralized gateways and public addresses reduce governance, while blocking inbound sessions does not prevent malicious outbound connections.

Question 9 (CISSP4-068) - Correct: A

Because separation is implemented through software-defined policy, automated validation and recurring isolation tests directly verify the control. A shared subnet, removal of tenant identifiers, or naming conventions do not enforce or demonstrate traffic separation.

Question 10 (CISSP4-069) - Correct: C

Distributed delivery and scrubbing can absorb traffic across multiple locations, while origin restrictions prevent direct bypass attacks. Publishing the origin defeats that protection, longer timeouts may consume more resources, and moving public content internally exposes a different trust zone.

Question 11 (CISSP4-070) - Correct: D

A stateful firewall maintains session context and can identify valid return traffic for connections initiated from inside. Address-only filtering lacks that context, while hubs and permissive route learning do not enforce connection-aware security policy.

Question 12 (CISSP4-071) - Correct: C

Redundant inline inspection and tested failover reduce the single point of failure while preserving prevention coverage, and an explicit failure policy defines exceptional behavior. Alert retention does not add resilience, unconditional silent bypass creates an uncontrolled path, and removing prevention abandons the required network control.

Question 13 (CISSP4-072) - Correct: A

Storm-control functionality limits excessive broadcast or multicast traffic at the source-facing switch port and can generate an alert. Larger or longer-lived address tables do not stop a flood, while dynamic trunking may extend the disturbance to additional VLANs.

Question 14 (CISSP4-073) - Correct: B

An opaque, integrity-protected value supports persistence without disclosing internal topology or accepting client manipulation. Publishing server details and trusting unvalidated routing input expose infrastructure and can let a client influence backend selection improperly.

Question 15 (CISSP4-074) - Correct: A, D

Protected conduit and controlled terminations reduce physical access, while shielding and monitoring help address electromagnetic leakage and tampering. Sensitive labels and public couplers increase exposure, and building characteristics alone do not provide reliable cable security.

Question 16 (CISSP4-075) - Correct: D

IPsec NAT traversal is designed to carry protected traffic across address-translating devices while retaining peer authentication and security policy. Direct exposure, plaintext routing, or disabling authentication sacrifices essential safeguards instead of solving the compatibility issue safely.

Question 17 (CISSP4-076) - Correct: B

A hardened access gateway concentrates authentication, authorization, logging, and revocation while keeping server management ports from direct exposure. Alternate port numbers do not prevent attacks, shared credentials remove attribution, and time-based direct exposure remains unnecessarily broad.

Question 18 (CISSP4-077) - Correct: A

A voice-aware boundary controller can authenticate the provider connection, enforce permitted call routes, and detect unusual signaling or toll patterns. Codec support does not prove source identity, broad destination access increases toll-fraud impact, and removing logs weakens detection and investigation.

Question 19 (CISSP4-078) - Correct: C, E

Identity-bound segmentation can follow a moving workload, and authenticated encryption protects overlay traffic across infrastructure outside the organization's control. Physical-port trust does not map reliably to mobile workloads, while removing policy or permitting all members defeats isolation.